

RAPBEEF Incident Investigation Report

Credential Compromise, Spearphishing, and Data Exfiltration at OWL Records

Analyst: Muhammad Essam
Role: Jr.Digital Forensic and SOC Analyst
Published by: 0xM4R7YR

Report Number	IR-2026-001	Severity	HIGH
Incident Period	April – May 2024 (Simulated)	Status	CONTAINED
Target Org	OWL Records	Phase Count	2 phases
Threat Actor	DCR-Hired Operator	Platform	Simulated

Contents

Executive Summary	3
1 Environment and Investigation Overview	4
1.1 Organization Profile	4
1.2 Threat Actor Profile	4
1.3 Investigation Initiation	4
2 Attack Chain	5
3 Phase 1 — Reconnaissance and Account Takeover	7
3.1 Web Reconnaissance	7
3.2 OSINT Collection — Lyrics as Attack Material	8
3.3 KBA Bypass and Email Account Compromise	8
3.4 Downstream Account Compromise — Instagram	9
3.5 Dark Web Post — Forensic Preservation Priority	9
4 Phase 2 — Phishing Campaign	10
4.1 PassiveDNS Infrastructure Pivot	10
4.2 Campaign Anatomy	10
4.3 Operation Timing Analysis	12
4.4 Psychological Targeting of Dwake	12
4.5 Click Confirmation and Credential Harvest	13
4.6 Post-Compromise Mailbox Reconnaissance and Exfiltration	14
5 MITRE ATT&CK Mapping	15
6 Indicators of Compromise	16
7 Defensive Recommendations	17
7.1 Technical Recommendations	17
7.2 Management Recommendations	17
8 Analyst Observations and Lessons Learned	18
8.0.1 The human factor is always the attack surface	18
8.0.2 Intel-led hunting requires different instincts than alert-driven triage	18
8.0.3 PassiveDNS pivoting from a single IOC	18
8.0.4 Psychological timing as a threat vector	18
A KQL Query Reference	19

Executive Summary

In early April 2024 (simulated), a threat actor hired by Dollar Currency Records (DCR) conducted a **two-phase cyber operation** against OWL Records and its primary artist, Dwake. **Phase one required zero technical exploitation:** personal details openly disclosed in Dwake’s own rap lyrics were used to bypass corporate knowledge-based authentication (KBA), achieving account takeover of both his corporate email and Instagram within a single session.

Phase two followed five days later — a targeted spearphishing campaign delivering **13 emails** to OWL Records personnel via domain betterlyrics4u[.]com, psychologically timed to exploit Dwake’s documented emotional vulnerability after the Instagram incident. Dwake clicked the malicious link **56 minutes** after delivery. The actor authenticated, conducted a systematic keyword search of Dwake’s mailbox, and exfiltrated DwakesDirtySecrets.zip on April 30th.

Metric	Finding
Total operation duration	April 10 – April 30, 2024 (20 days)
Initial access method	KBA bypass using OSINT from public rap lyrics
Accounts compromised	2 (corporate email + Instagram)
Phishing emails delivered	13 (targeting OWL Records rappers)
Time-to-click (spearphish)	56 minutes after delivery
Time-to-auth (post-click)	60 minutes after click
Data exfiltrated	DwakesDirtySecrets.zip (Drafts folder)
Overall severity	HIGH

1 Environment and Investigation Overview

1.1 Organization Profile

OWL Records is a music label whose environment includes artist management, internal email infrastructure, and a public-facing website exposing artist contact information. At the time of the incident, account recovery relied exclusively on Knowledge-Based Authentication (KBA) security questions — a mechanism NIST formally deprecated in SP 800-63B in 2017.

1.2 Threat Actor Profile

The threat actor is assessed with moderate confidence to be a contractor hired by Dollar Currency Records (DCR). The actor operated from a single IP address (18.66.52.227) across all phases of the operation, indicating consistent infrastructure reuse. Attribution is based on human intelligence, PassiveDNS correlation, and cross-table log analysis.

1.3 Investigation Initiation

Intel-led hunt, not alert-driven. This investigation was initiated by a human intelligence source who reported that DCR had engaged a threat actor and provided the associated IP address (18.66.52.227). The practical consequence was methodological: the correct first data source was *InboundNetworkEvents*, not the authentication logs an alert-driven triage would typically start from. Matching the starting log source to the current attack phase is a core investigative discipline documented throughout this report.

Log sources queried: InboundNetworkEvents · OutboundNetworkEvents · Email · PassiveDns · AuthenticationEvents · Employees

2 Attack Chain

The following timeline reconstructs the complete operation across both phases. Color coding: **blue** = reconnaissance, **amber** = pivot point, **red** = compromise or exfiltration event.

PHASE 1 — STEP 1: Web Reconnaissance

10/04/2024, pre-10:57

Threat actor at 18.66.52.227 issues 19 HTTP requests to the OWL Records website, methodically browsing artist profiles. Dwake's corporate email address (dwake_audrey@owl-records.com) is extracted from the public-facing artist page.

PIVOT — OSINT: Lyrics Become Attack Material

10/04/2024

Actor cross-references Dwake's recently released diss track. Two lines of lyric content map directly to KBA security questions on the OWL Records password reset portal: **mother's maiden name** (*Washington*) and **childhood pet name** (*Fluffy*). No technical tools required.

PHASE 1 — STEP 2: KBA Bypass & Corporate Email Takeover

10/04/2024, 10:57

Password reset submitted with harvested answers. Reset succeeds. Corporate email account fully compromised. Actor now controls the inbox.

PHASE 1 — STEP 3: Instagram Account Takeover

10/04/2024, same session

Actor uses "forgot password" on Instagram, routing the recovery email to the now-controlled inbox. Instagram compromised within the same session. Embarrassing image posted to Dwake's public profile the following day. Reputational damage confirmed.

PHASE 2 — STEP 1: Phishing Infrastructure Identified

10/04/2024, 14:45

Phishing campaign launched via domain betterlyrics4u[.]com, resolving to attacker IP 18.66.52.227. 13 emails delivered to OWL Records rappers from two sender addresses. Identified during investigation via PassiveDNS pivot.

PHASE 2 — STEP 2: Spearphish Delivered to Dwake

15/04/2024, 11:07

Targeted email arrives at dwake_audrey@owl-records.com with subject [EXTERNAL] RE: *Need a ghostwriter for your next hit?* Email passes corporate security filter. Verdict: **CLEAN**.

PHASE 2 — STEP 3: Dwake Clicks the Link

15/04/2024, 12:03

OutboundNetworkEvents confirms click from Dwake's internal IP 10.10.0.5 to [http://betterlyrics4u\[.\]com/share/online/published/enter](http://betterlyrics4u[.]com/share/online/published/enter). Time-to-click: **56 minutes** after email delivery.

PHASE 2 — STEP 4: Credential Harvest & Successful Authentication

15/04/2024, 13:03

Successful authentication recorded in AuthenticationEvents for dwaudrey from attacker IP 18.66.52.227. Password hash captured: 8f8d7baf48abc18667315891d4c6a507. Time from click to auth: **60 minutes**.

PHASE 2 — STEP 5: Mailbox Reconnaissance & Data Exfiltration

16/04 -- 30/04/2024

Actor conducts systematic keyword search across Dwake's mailbox over April 16th (*scandal, confidential, leak, secret, sensitive, meeting_notes, private_emails, employee_complaints*). On April 30th at 14:23:02Z, DwakesDirtySecrets.zip is downloaded from Dwake's Drafts folder. **Exfiltration confirmed.**

3 Phase 1 — Reconnaissance and Account Takeover

3.1 Web Reconnaissance

Querying InboundNetworkEvents for the reported IP over April 10th returned **19 distinct HTTP requests** to the OWL Records website.

Listing 1: Query 1 — Attacker IP web activity

```
InboundNetworkEvents
| where timestamp between (datetime("2024-04-10T00:00:00"))
                        .. datetime("2024-04-11T00:00:00"))
| where src_ip has "18.66.52.227"
// Result: 19 rows
```

Analysis of the URL column revealed a non-random, methodical browsing pattern converging on Dwake's profile and the password reset flow. The reset-password parameter appearing in the URL column confirmed intent before the bypass was executed.

ANALYST OBSERVATION

A URL is not just a web address. It is a timestamped record of intent. The reset-password parameter in the logs was not a technical finding — it was a confession. The attacker documented their own plan in the log before executing it. Most analysts start with authentication logs. In this case, that would have been the wrong move — the attacker hadn't touched authentication yet. Starting from InboundNetworkEvents was the correct call because that matched the current phase of the attack.

Table 1		Search	2026-05-05 19:47 (UTC)	# 19	Hide empty columns
timestamp	src_ip	url	status		
> 10/04/2024, 00:00:00	GET 18.66.52.227	Mozilla/ https://owl-records.com/search=whats+Dwake%27s+email+address%3F	200		
> 10/04/2024, 10:50:35	GET 18.66.52.227	Mozilla/ https://owl-records.com/search=OWL+Records+rapper+contact+info	200		
> 10/04/2024, 10:51:10	GET 18.66.52.227	Mozilla/ https://owl-records.com/search=OWL+Records+artists+contact+details	200		
> 10/04/2024, 10:51:34	GET 18.66.52.227	Mozilla/ https://owl-records.com/search=how+do+i+email+Dwake%3F%3F	200		
> 10/04/2024, 10:51:55	GET 18.66.52.227	Mozilla/ https://owl-records.com/search=Dwake+booking+info+pls	200		
> 10/04/2024, 10:52:00	GET 18.66.52.227	Mozilla/ https://owl-records.com/search=OWL+Records+artist+email+directory	200		
> 10/04/2024, 10:52:02	GET 18.66.52.227	Mozilla/ https://owl-records.com/search=can+i+book+Dwake+for+a+party%3F	200		
> 10/04/2024, 10:52:38	GET 18.66.52.227	Mozilla/ https://owl-records.com/search=why+is+Dwake+music+much+soo+trasshhh	200		
> 10/04/2024, 10:53:07	GET 18.66.52.227	Mozilla/ https://owl-records.com/artists/Dwake/	200		
> 10/04/2024, 10:53:42	GET 18.66.52.227	Mozilla/ https://owl-records.com/artists/email_contacts/	200		
> 10/04/2024, 10:54:15	GET 18.66.52.227	Mozilla/ https://owl-records.com/artists/booking_info/	200		
> 10/04/2024, 10:55:08	GET 18.66.52.227	Mozilla/ https://owl-records.com/events/OWLRecords_concerts_2024/	200		
> 10/04/2024, 10:55:56	GET 18.66.52.227	Mozilla/ https://owl-records.com/marketing/artist_profiles/	200		
> 10/04/2024, 10:56:30	GET 18.66.52.227	Mozilla/ https://owl-records.com/marketing/press_releases/	200		
> 10/04/2024, 10:57:03	GET 18.66.52.227	Mozilla/ https://owl-records.com/legal/contact_us/	200		
> 10/04/2024, 10:57:47	GET 18.66.52.227	Mozilla/ https://owl-records.com/account/reset-password?username=dwaubrey&email=dwake_audre	200		
> 10/04/2024, 11:56:47	GET 18.66.52.227	Mozilla/ https://owl-records.com/support/request-password-reset?username=dwaubrey&reason=For	200		
> 10/04/2024, 12:53:47	GET 18.66.52.227	Mozilla/ https://owl-records.com/account/security-questions?username=dwaubrey	200		

Figure 1: InboundNetworkEvents — 19 rows | URL column showing reset-password parameter

3.2 OSINT Collection — Lyrics as Attack Material

The actor's ability to answer the KBA security questions required no hacking tools. It required listening to Dwake's diss track.

OSINT Mapping: Lyrics to Security Question Answers

Lyric	Security Answer Disclosed
"Got the Washington name from my mom's side, son"	→ Mother's maiden name: Washington (Q1)
"Used to play with little Fluffy, now I'm runnin' with the wolves"	→ Childhood pet's name: Fluffy (Q3)

Two security questions. Two bars. The entire authentication bypass was publicly available on streaming platforms before the attack began.

ANALYST OBSERVATION

I'll be honest: I can smell ghost writers from here. No artist who writes their own bars would hand out their mother's maiden name and childhood pet in back-to-back lines without noticing. That is a talent management problem, not a security problem. Our job is the investigation, not the music review.

It is also worth noting that "little Fluffy" *could* refer to a person rather than a pet. In a real investigation this ambiguity would require corroboration before drawing conclusions. In this case, the authentication logs confirmed the intended interpretation.

3.3 KBA Bypass and Email Account Compromise

With email address and security answers in hand, the actor submitted a password reset. The URL captured in InboundNetworkEvents confirms the bypass was executed:

Listing 2: Password reset URL confirming KBA bypass — captured in logs

```
https://owl-records.com/account/security-questions
?question_1=mother's+maiden+name&answer_1=Washington
&question_2=first+pet's+name&answer_2=Fluffy
```

>	10/04/2024, 10:55:56	GET	18.66.52.227	Mozilla/5.0	https://owl-records.com/marketing/artist_profiles/
>	10/04/2024, 10:56:30	GET	18.66.52.227	Mozilla/5.0	https://owl-records.com/marketing/press_releases/
>	10/04/2024, 10:57:03	GET	18.66.52.227	Mozilla/5.0	https://owl-records.com/legal/contact_us/
>	10/04/2024, 10:57:47	GET	18.66.52.227	Mozilla/5.0	https://owl-records.com/account/reset-password?username=dwaubrey&email=dwake_audrey@owl-records.com
>	10/04/2024, 11:56:47	GET	18.66.52.227	Mozilla/5.0	https://owl-records.com/support/request-password-reset?username=dwaubrey&reason=Forgot+my+password
>	10/04/2024, 12:53:47	GET	18.66.52.227	Mozilla/5.0	https://owl-records.com/account/security-questions?username=dwaubrey
>	10/04/2024, 13:02:47	GET	18.66.52.227	Mozilla/5.0	https://owl-records.com/account/security-questions?question_1=mother's+maiden+name&answer_1=Washington&question_2=first+pet's+name&answer_2=Fluffy

Figure 2: InboundNetworkEvents — URL containing washington and fluffy parameters, reset-password confirmed

ANALYST OBSERVATION

Dwake shows no signs of security literacy — and to be fair to him, nobody gave him any. OWL Records was using KBA as its primary account protection. NIST deprecated KBA in 2017. When your security policy is weaker than your artist's OPSEC, the blame belongs to the policy, not the person. This is an organizational failure wearing a human face.

3.4 Downstream Account Compromise — Instagram

Following email account compromise, the actor used Instagram's "forgot password" flow, routing the recovery link to the now-controlled inbox. The Instagram account fell within the same session. An embarrassing image was posted the following day. Reputational damage: confirmed. Technical sophistication required: none.

3.5 Dark Web Post — Forensic Preservation Priority

The day after the Instagram incident, a dark web forum post threatened to release damaging material on Present (DCR's own artist) unless he retired within 30 days. The timing created an appearance of OWL Records involvement. As the investigating analyst, the immediate forensic priority shifted to establishing a documented evidence chain demonstrating non-involvement — exculpatory evidence produced and preserved with the same rigor as incriminating evidence.

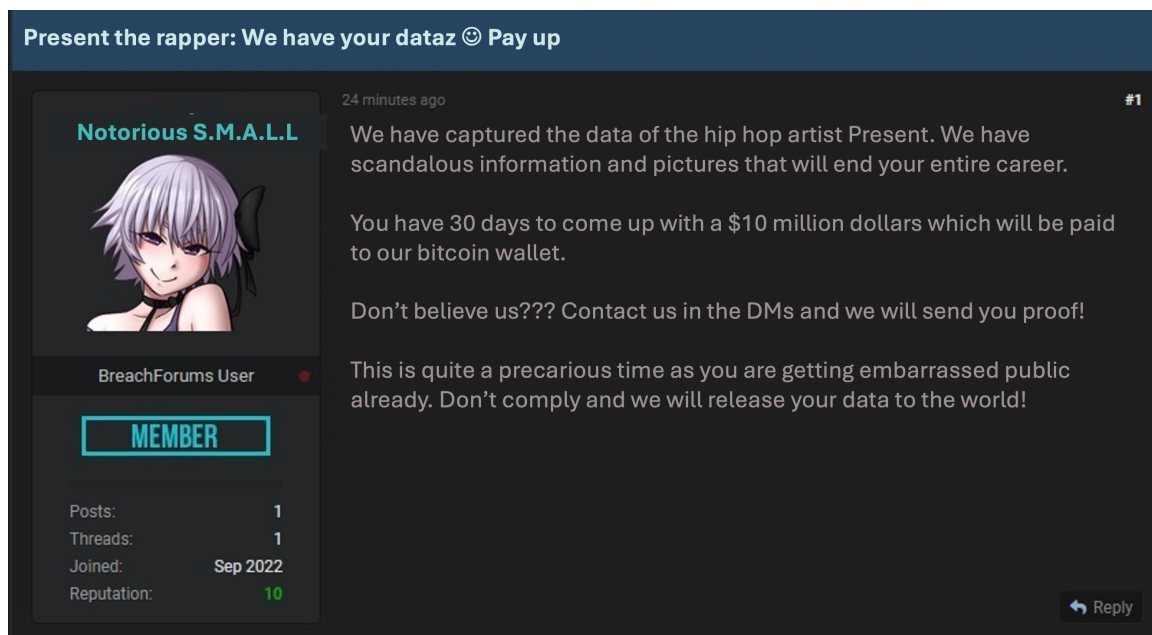


Figure 3: Dark Web Posting

4 Phase 2 — Phishing Campaign

4.1 PassiveDNS Infrastructure Pivot

Returning to the one confirmed IOC — attacker IP 18.66.52.227 — a PassiveDNS query mapped the IP to a previously unknown domain:

Listing 3: Query 2 — PassiveDNS pivot from attacker IP

```
PassiveDns
| where ip == "18.66.52.227"
// Result: betterlyrics4u[.]com
```

timestamp	ip	domain
> 07/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 07/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 07/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 07/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 07/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 07/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 08/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 09/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 09/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com
> 09/04/2024, 07:50:13	18.66.52.227	betterlyrics4u.com

Figure 4: PassiveDNS result — betterlyrics4u.com resolving to 18.66.52.227

Result: betterlyrics4u[.]com. A single IP address, provided by a human source, became the thread that unravelled the entire second phase. This is the core discipline of infrastructure pivoting: one confirmed IOC is sufficient to reconstruct a campaign, when the right tables are queried in sequence.

What is Passive DNS? Passive DNS is a historical database recording domain-to-IP mappings over time. Unlike live DNS resolution, it reveals what domains have resolved to a given IP in the past — and what other IP addresses a domain has historically pointed to. Attackers frequently reuse infrastructure across operations, making PassiveDNS one of the most effective pivoting tools available to a threat hunter.

4.2 Campaign Anatomy

Listing 4: Query 3 — Full phishing campaign scope

```
Email
| where link has "betterlyrics4u.com"
// Result: 13 emails
```

timestamp	sender	reply_to	recipient	subject	verdict	link
> 10/04/2024, 14:45:28	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	ice_blake@owl-records.com	[EXTERNAL] Get FREE bea	CLEAN	https://betterlyrics4u.com/
> 10/04/2024, 14:45:28	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	nikki_lane@owl-records.com	[EXTERNAL] Get FREE bea	CLEAN	https://betterlyrics4u.com/
> 11/04/2024, 08:50:10	wemakebeatz@gmail.com	wemakebeatz@gmail.co	jay_knight@owl-records.com	[EXTERNAL] FW: Get FREE	BLOCKED	https://betterlyrics4u.com/
> 11/04/2024, 08:50:10	wemakebeatz@gmail.com	wemakebeatz@gmail.co	jay_knight@owl-records.com	[EXTERNAL] FW: Get FREE	BLOCKED	https://betterlyrics4u.com/
> 12/04/2024, 13:37:39	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	lil_zee@owl-records.com	[EXTERNAL] Need a ghost	CLEAN	https://betterlyrics4u.com/
> 12/04/2024, 13:37:39	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	jay_knight@owl-records.com	[EXTERNAL] Need a ghost	CLEAN	https://betterlyrics4u.com/
> 15/04/2024, 11:07:12	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	dwake_audrey@owl-records.com	[EXTERNAL] RE: Need a gh	CLEAN	http://betterlyrics4u.com/
> 15/04/2024, 11:07:12	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	snoop_thompson@owl-records.com	[EXTERNAL] RE: Need a gh	CLEAN	http://betterlyrics4u.com/
> 17/04/2024, 09:46:37	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	justin_cole@owl-records.com	[EXTERNAL] RE-RE: Need a	CLEAN	https://betterlyrics4u.com/
> 17/04/2024, 09:46:37	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	chance_west@owl-records.com	[EXTERNAL] RE-RE: Need a	CLEAN	https://betterlyrics4u.com/
> 19/04/2024, 13:45:27	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	drake_hill@owl-records.com	[EXTERNAL] Need a ghost	CLEAN	http://betterlyrics4u.com/
> 19/04/2024, 13:45:27	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	drake_hill@owl-records.com	[EXTERNAL] Need a ghost	CLEAN	http://betterlyrics4u.com/
> 25/04/2024, 14:36:33	ghostwritersanonymous@protonmail.com	ghostwritersanonymous	logic_white@owl-records.com	[EXTERNAL] Get FREE bea	CLEAN	https://betterlyrics4u.com/

Figure 5: Email table — 13 results, betterlyrics4u.com in link column

Sender Address	Count	Platform
ghostwritersanonymous@protonmail.com	11	ProtonMail
wemakebeatz@gmail.com	2	Gmail
Total	13	

Cross-referencing recipients against the Employees table confirmed role-specific targeting:

Listing 5: Query 4 — Identifying targeted employee roles

```
let _targets = Email
| where link has "betterlyrics4u.com"
| distinct recipient;
Employees
| where email_addr in (_targets)
// Result: all targets = Rapper role
```

email_addr	email_addr	company_domain	username	role	hostname
0.10.0.14	drake_hill@owl-records.com	owl-records.com	drhill	Rapper	XWR2-LAPTOP
0.10.0.18	chance_west@owl-records.com	owl-records.com	chwest	Rapper	GJDR-DESKTOP
0.10.0.26	nikki_lane@owl-records.com	owl-records.com	nilane	Rapper	UCVH-MACHINE
0.10.0.16	lil_zee@owl-records.com	owl-records.com	lizee	Rapper	OIHK-LAPTOP
0.10.0.21	snoop_thompson@owl-records.com	owl-records.com	snthompson	Rapper	QGAC-LAPTOP
0.10.0.8	jay_knight@owl-records.com	owl-records.com	jaknight	Rapper	HUVN-DESKTOP
0.10.0.5	dwake_audrey@owl-records.com	owl-records.com	dwaudrey	Lead Rapper	8GZI-DESKTOP
0.10.0.20	logic_white@owl-records.com	owl-records.com	lowwhite	Rapper	CUWN-MACHINE
0.10.0.29	justin_cole@owl-records.com	owl-records.com	jucole	Rapper	5HUM-MACHINE
0.10.0.24	ice_blake@owl-records.com	owl-records.com	icblake	Rapper	IH9V-LAPTOP

Figure 6: Employees cross-reference — all 13 targets hold Rapper job title

ANALYST OBSERVATION

The phishing subject lines were: “Get FREE beats from the best hip hop writers in the game!!!” and “Need a ghostwriter for your next hit?” Targeted at people who, evidently, use ghostwriters.

This tells you two things simultaneously: the attacker did their homework, and OWL Records has a ghost-writing dependency that is not a well-kept secret. The security gap and the talent gap are the same gap.

4.3 Operation Timing Analysis

Event	Timestamp	Phase
KBA bypass executed	10/04/2024, 10:57	Phase 1
Phishing campaign begins	10/04/2024, 14:45	Phase 2
Spearphish delivered to Dwake	15/04/2024, 11:07	Phase 2
Dwake clicks link	15/04/2024, 12:03	Phase 2
Attacker authenticates	15/04/2024, 13:03	Phase 2
Mailbox recon begins	16/04/2024, 09:49	Phase 2
Exfiltration complete	30/04/2024, 14:23	Phase 2

Phase 1 (KBA bypass) preceded the phishing campaign by approximately 4 hours on the same day. Phase 2 was deployed after the actor confirmed access to OWL Records infrastructure and understood the target environment.

4.4 Psychological Targeting of Dwake

Dwake's spearphish arrived on April 15th — **five days** after the Instagram post that publicly embarrassed him. The email was timed to arrive when the target was most emotionally vulnerable and most likely to want a solution.

12/04/2024, 13:37:39	ghostwritersanonymoi	ghostwritersanonymoi	jay_knight@owl-recon	[EXTERNAL] Need a gl	CLEAN	https://betterlyrics4u.cc
15/04/2024, 11:07:12	ghostwritersanonymoi	ghostwritersanonymoi	dwake_audrey@owl-r	[EXTERNAL] RE: Need	CLEAN	http://betterlyrics4u.cc
15/04/2024, 11:07:12	ghostwritersanonymoi	ghostwritersanonymoi	snoop_thompson@ow	[EXTERNAL] RE: Need	CLEAN	http://betterlyrics4u.cc

Figure 7: Phishing email to Dwake — subject line, GhostWriter signature, CLEAN verdict

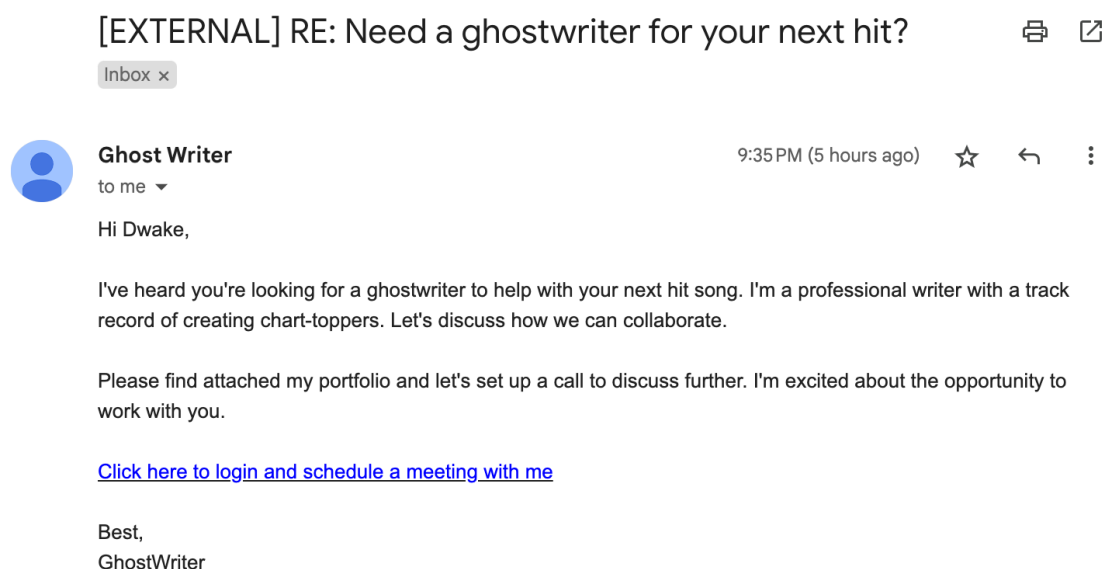


Figure 8: Screenshot of phishing email sent to and clicked by Dwake

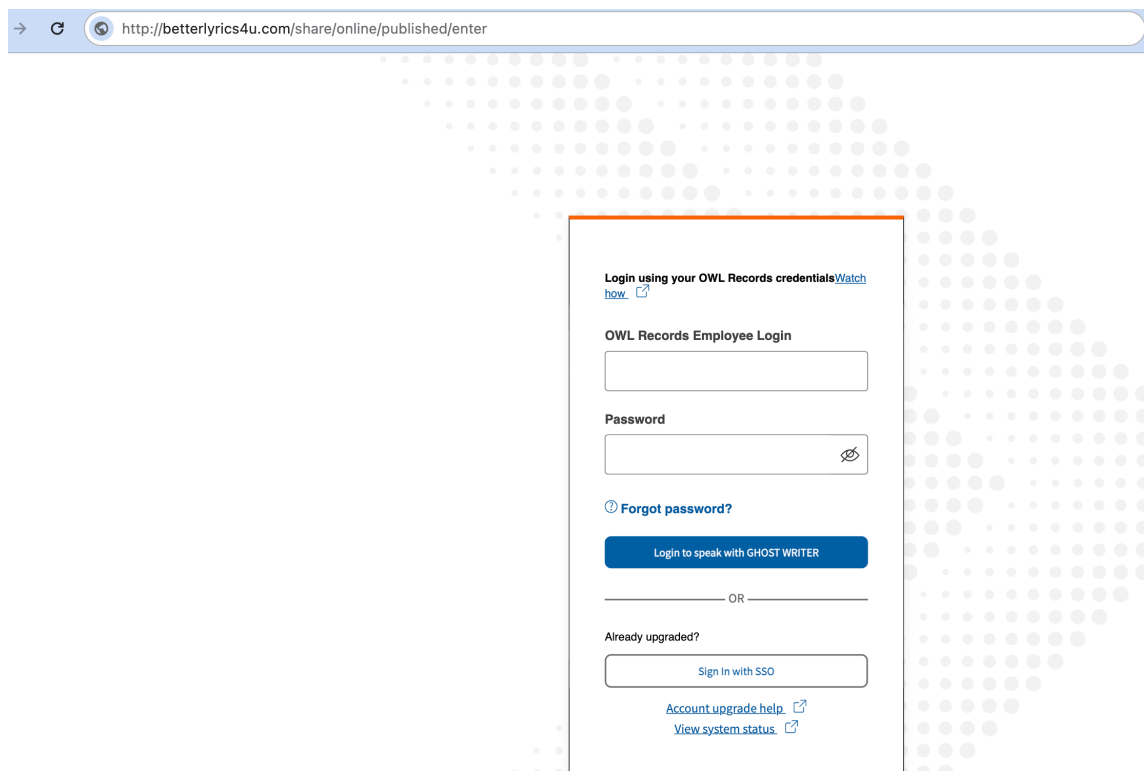


Figure 9: Phishing page — “Login to speak with GHOST WRITER” button

ANALYST OBSERVATION

This is textbook adversarial psychology. You do not attack a target when they are calm and thinking clearly. You attack them when they are emotional, embarrassed, and actively looking for a way to recover their status. The attacker waited five days — long enough for the humiliation to settle, short enough that it was still raw. This is precisely why security awareness training that only teaches “do not click suspicious links” is insufficient: a link does not feel suspicious when you are desperate for what it appears to offer.

4.5 Click Confirmation and Credential Harvest

Listing 6: Query 5 — Confirming Dwake clicked the phishing link

```
OutboundNetworkEvents
| where url == "http://betterlyrics4u.com/share/online/published/enter"
| where src_ip == "10.10.0.5"
// Result: click confirmed 2024-04-15T12:03:12Z
```

timestamp	method	src_ip	user_agent	url
15/04/2024, 12:03:12	GET	10.10.0.5	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0	http://betterlyrics4u.com/share/online/published/enter

Figure 10: OutboundNetworkEvents — Dwake’s IP 10.10.0.5, URL, timestamp 12:03:12Z

Click confirmed at 2024-04-15T12:03:12Z — 56 minutes after delivery. The URL's use of http rather than https is noted as a basic fraud indicator that security-aware users would recognize immediately.

Listing 7: Query 6 — Attacker authentication with stolen credentials

```
AuthenticationEvents
| where username == "dwardrey"
| where src_ip == "18.66.52.227"
// Result: successful login 2024-04-15T13:03:12Z
```

timestamp	hostname	src_ip	user_agent	username	result	password_hash
15/04/2024, 13:03:12	MAIL-SERVER01	18.66.52.227	Mozilla/5.0 (compatible; MSIE 6.0; Windows NT 6.2; Trident/	dwardrey	Successful Login	8f8d7baf48abc18667315891d4c6

Figure 11: AuthenticationEvents — dwardrey, src_ip 18.66.52.227, successful login, hash captured

Successful authentication at 2024-04-15T13:03:12Z. Time from click to authenticated session: **60 minutes**.

4.6 Post-Compromise Mailbox Reconnaissance and Exfiltration

Listing 8: Query 7 — Post-compromise activity in Dwake's account

```
InboundNetworkEvents
| where timestamp between (datetime("2024-04-12T00:00:00"))
                        .. datetime("2024-05-01T00:00:00"))
| where url has "dwardrey"
| where src_ip has "18.66.52.227"
```

timestamp	src_ip	url
16/04/2024, 09:49:32	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/search?query=scandal
16/04/2024, 09:50:04	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/search?query=confidential
16/04/2024, 09:50:13	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/search?query=leak
16/04/2024, 09:50:23	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/search?query=secret
16/04/2024, 09:50:27	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/search?query=sensitive
16/04/2024, 09:51:12	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/drafts/
16/04/2024, 09:51:59	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/internal_communications/meeting_notes/
16/04/2024, 09:52:09	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/internal_communications/private_emails/
16/04/2024, 09:52:41	18.66.52.227	Mozi https://owl-records.com/mail?user=dwardrey/internal_communications/employee_complaints/
30/04/2024, 14:23:02	18.66.52.227	Mozi https://owl-records.com/mail/readmail?user=dwardrey%40owl-records.com&mailbox_folder=Drafts&download=true&output=DwakesDirtySecrets.zip

Figure 12: InboundNetworkEvents — keyword search URLs and DwakesDirtySecrets.zip download URL

Keyword search sequence executed across April 16th:

scandal · confidential · leak · secret · sensitive
meeting_notes · private_emails · employee_complaints

CRITICAL FINDING

On April 30th at 14:23:02Z, the actor downloaded DwakesDirtySecrets.zip from Dwake's Drafts folder via authenticated web session. **Data exfiltration is confirmed.** The file name and search pattern indicate the attacker's goal was blackmail-grade material rather than financial fraud.

5 MITRE ATT&CK Mapping

Technique	ID	Real-World Anchor
Gather victim identity info via public media	T1589	LAPSUS\$ routinely harvested personal data from social media and public sources to bypass KBA controls — same technique, different channel
Modify authentication process — security questions	T1556	NIST SP 800-63B deprecated KBA in 2017. CISA advisory AA22-011A flags it as insufficient. No justification for its continued use exists
Compromise accounts — email accounts	T1586.002	Email compromise as a pivot to downstream accounts (social, SaaS) is the first step in the majority of documented BEC and ATO chains
Phishing — spearphishing link	T1566.002	Role-specific targeting (Rappers only) mirrors precision social engineering documented in Proofpoint's 2023 State of Phish report
Valid accounts	T1078	Authenticated access via stolen credentials is indistinguishable from legitimate login without behavioral baselines in place
Email collection — local	T1114	Systematic keyword-based mailbox search for blackmail material mirrors post-compromise behavior in documented BEC actor playbooks
Exfiltration over web service	T1567	Zip archive download via authenticated session requires no external tooling and blends naturally with legitimate traffic
Search open technical databases — passive DNS	T1596.001	Used <i>defensively</i> here: infrastructure pivoting from a single IOC to a full phishing campaign via PassiveDNS

tabularx xurl array

6 Indicators of Compromise

INDICATORS OF COMPROMISE

Indicator	Type	Context
18.66.52[.]227	IP	Attacker exit node — recon, auth, phishing infra
betterlyrics4u[.]com	Domain	Phishing domain — PassiveDNS pivot
ghostwritersanonymous@protonmail.com	Email	Primary sender — 11 phishing emails
wemakebeatz@gmail.com	Email	Secondary sender — 2 phishing emails
.../share/online/published/enter	URL	Credential harvesting page
dwake_audrey@owl-records.com	Email	Compromised account
10.10.0.5	IP	Dwake's internal IP — click confirmed
DwakesDirtySecrets.zip	File	Exfiltrated archive — 30/04/2024 14:23Z
8f8d7baf48abc18667315891d4c6a507	Hash	Password hash captured in auth log

7 Defensive Recommendations

7.1 Technical Recommendations

- **Eliminate KBA security questions immediately.** Replace with FIDO2/passkeys or hardware MFA. NIST deprecated KBA in 2017. This single change removes the entire Phase 1 attack vector permanently.

Listing 9: Detection: alert on password reset events for high-profile accounts

```
AuthenticationEvents
| where EventType == "PasswordReset"
| where username in (high_value_accounts)
```

- **Block newly registered domains at the email gateway.** `betterlyrics4u[.]com` had no legitimate business history. A domain age filter of ≤ 30 days would have blocked the phishing delivery entirely.
- **Flag outbound HTTP (non-HTTPS) link clicks.** Filter `OutboundNetworkEvents` for `http://` URLs accessed from internal IPs. Legitimate corporate services do not use unencrypted HTTP.
- **Monitor for bulk keyword searches in authenticated mailbox sessions.** A sequence of queries for *scandal*, *confidential*, *leak* within a single session is not normal user behavior. Implement behavioral alerting on mailbox audit logs.
- **Implement email security reconfiguration.** The phishing email received a verdict of CLEAN from the corporate security product. The tool requires reconfiguration to detect role-targeted social engineering.

7.2 Management Recommendations

- **Root cause: policy failure, not user failure.** KBA is trivia, not authentication. Removing it eliminates this attack surface at the organizational level. The artist cannot be blamed for a policy the organization chose.
- **High-profile employees carry elevated OSINT exposure.** Standard security awareness training does not account for this. Artists, executives, and other public-facing staff require bespoke OPSEC briefings covering what should never appear in public creative output, interviews, or social media.
- **Incident severity: HIGH.** Exfiltration is confirmed. Blackmail-grade material is in attacker possession. Treat as an active high-severity incident until full remediation is documented.

8 Analyst Observations and Lessons Learned

The human factor is always the attack surface

RAPBEEF contains no malware, no zero-day, no advanced technique. Every step was enabled by things already broken before the attacker arrived: a deprecated authentication mechanism, an artist with zero security training, an email filter that could not detect social engineering, and no behavioral monitoring inside authenticated sessions. The attacker's only skill was recognizing what was broken and walking through the door.

Intel-led hunting requires different instincts than alert-driven triage

When the investigation started from a human intelligence tip rather than a SIEM alert, the methodology had to adapt immediately. The instinct to start with authentication logs — the comfortable default — would have been wrong because the attacker had not yet touched the authentication layer at the time of the tip. Matching the starting log source to the current attack phase is a transferable discipline that develops through practice, not theory.

PassiveDNS pivoting from a single IOC

The most significant investigative moment was resolving the attacker's IP to `betterlyrics4u[.]com` via PassiveDNS, and from that domain extracting the full 13-email phishing campaign. Starting from one piece of human intelligence, the investigation unravelled a complete two-phase operation across four log sources. That pivoting discipline — following the data rather than the assumption — is what separates systematic investigation from lucky guesswork.

Psychological timing as a threat vector

The five-day gap between the Instagram post and the phishing email was deliberate. The attacker staged delivery to maximize emotional vulnerability at the exact moment when Dwake was most likely to act without thinking. Defending against this requires security training that addresses human psychology under pressure, not just technical indicators to look for before clicking.

A KQL Query Reference

Q1 — Attacker IP Reconnaissance Activity

```
InboundNetworkEvents
| where timestamp between (datetime("2024-04-10T00:00:00"))
                        .. datetime("2024-04-11T00:00:00"))
| where src_ip has "18.66.52.227"
// Returns: 19 results
```

Q2 — KBA Bypass Confirmation

```
InboundNetworkEvents
| where timestamp between (datetime("2024-04-10T00:00:00"))
                        .. datetime("2024-04-11T00:00:00"))
| where url has_any("washington", "fluffy")
| where src_ip has "18.66.52.227"
// Returns: full reset-password URL with harvested answers
```

Q3 — PassiveDNS Infrastructure Pivot

```
PassiveDns
| where ip == "18.66.52.227"
// Returns: betterlyrics4u[.]com
```

Q4 — Full Phishing Campaign Scope

```
Email
| where link has "betterlyrics4u.com"
// Returns: 13 emails
```

Q5 — Targeted Employee Role Identification

```
let _targets = Email
| where link has "betterlyrics4u.com"
| distinct recipient;
Employees
| where email_addr in (_targets)
// Returns: all targets = Rapper role
```

Q6 — Click Confirmation

```
OutboundNetworkEvents
| where url == "http://betterlyrics4u.com/share/online/published/enter"
| where src_ip == "10.10.0.5"
// Returns: click confirmed 2024-04-15T12:03:12Z
```

Q7 — Attacker Authentication

```
AuthenticationEvents
| where username == "dwaudrey"
| where src_ip == "18.66.52.227"
// Returns: successful login 2024-04-15T13:03:12Z
```

Q8 — Post-Compromise Mailbox Activity

```
InboundNetworkEvents
| where timestamp between (datetime("2024-04-12T00:00:00"))
                        .. datetime("2024-05-01T00:00:00"))
| where url has "dwaudrey"
| where src_ip has "18.66.52.227"
// Returns: keyword searches + DwakesDirtySecrets.zip download
```

About this report: This investigation was conducted in KC7, a free cybersecurity training platform built by former Microsoft DART analysts. All company names, artists, IP addresses, and individuals are entirely simulated. This write-up follows real-world SOC incident reporting standards and is published as part of **Muhammad Essam's** public cybersecurity portfolio. [Connect with me on LinkedIn.](#)